

《数据库原理及应用教程（MySQL）》

第8章 数据库安全性管理



01

OPTION

数据库安全性定义

Security

02

OPTION

MySQL权限系统

MySQL Privilege

03

OPTION

MySQL用户管理

MySQL User Admin

04

OPTION

MySQL权限管理

MySQL Privilege Admin

05

OPTION

MySQL角色管理

MySQL Role Admin



安全性涉及多个方面

法律、社会和伦理方面的问题

物理控制方面的问题

政策方面的问题

运行方面的问题

硬件控制方面的问题

操作系统安全性方面的问题

数据库系统本身的安全性方面的问题



安全性控制的一般方法



用户标识和鉴定的实现方法:

使用用户名或用户标识符来标明用户的凭证

将用户名 (Username) 与口令 (Password) 结合作为用户凭证



使用其他辅助设备或信息, 如手机短信、IP位置信息和口令卡等

用户存取权限控制:

用户存取权限是指用户对于不同的数据对象（库、表、视图等）允许执行的操作权限。



定义视图:

为不同的用户定义相应视图，可以限制各个用户的访问范围。

文件加密:

前面介绍的几种数据库安全措施, 都是防止从数据库系统窃取保密数据, 不能防止用户通过不正常渠道非法访问数据?

加密技术



为了防止数据窃取问题, 可对存储在文件系统上的数据文件进行加密 (Data Encryption)

安全审计:

对于某些高度敏感的关键数据, 可以通过数据库日志记录数据各类操, 并施加数据审计, 监控数据库操作记录, 分析数据库潜在的安全漏洞

01

OPTION

数据库安全性定义

Security

02

OPTION

MySQL权限系统

MySQL Privilege

03

OPTION

MySQL用户管理

MySQL User Admin

04

OPTION

MySQL权限管理

MySQL Privilege Admin

05

OPTION

MySQL角色管理

MySQL Role Admin



权限管理机制

- 根据用户提供的信息，
对照mysql.user表中记录，验证用户身份。

用户名

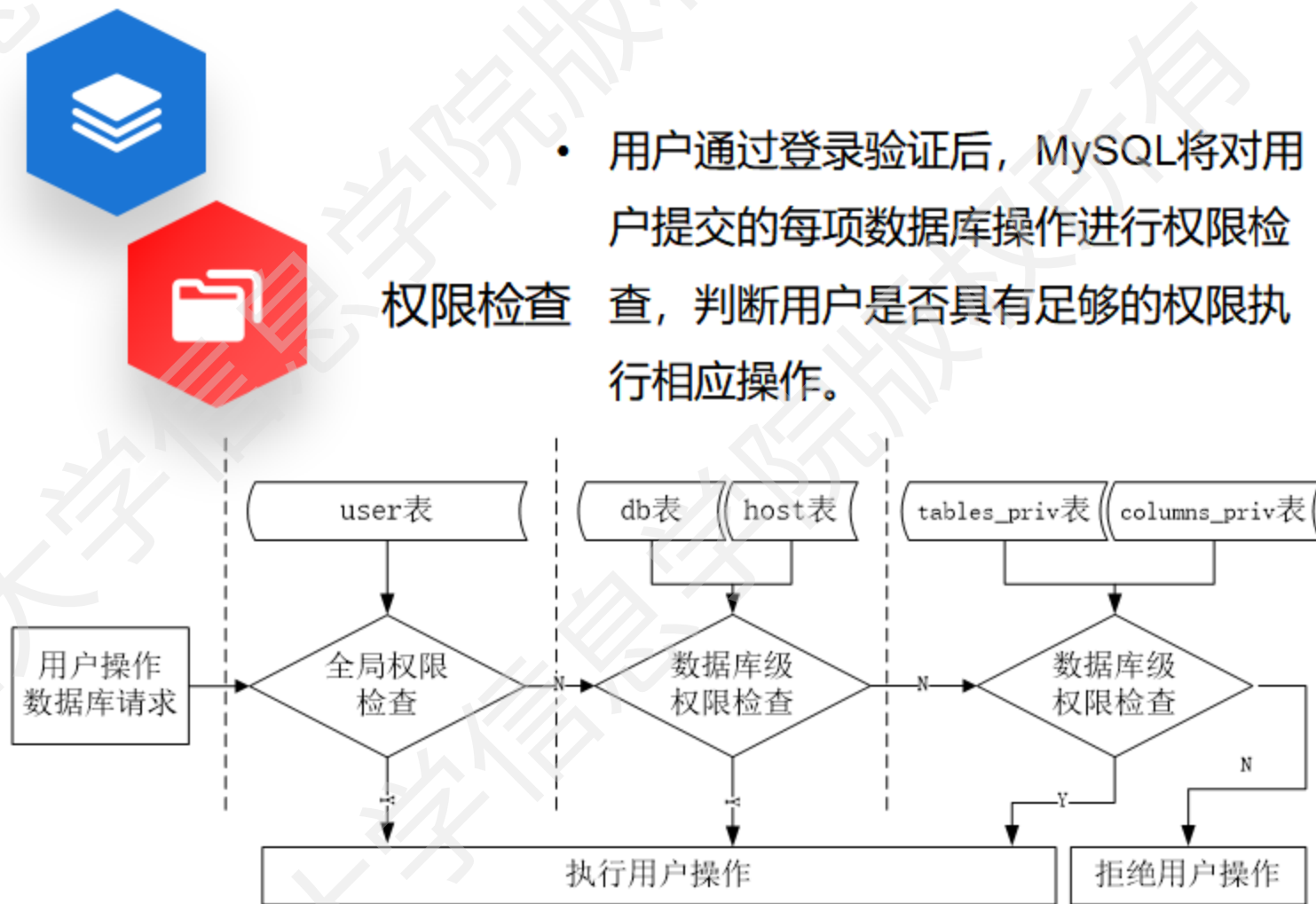
密码

地址信息

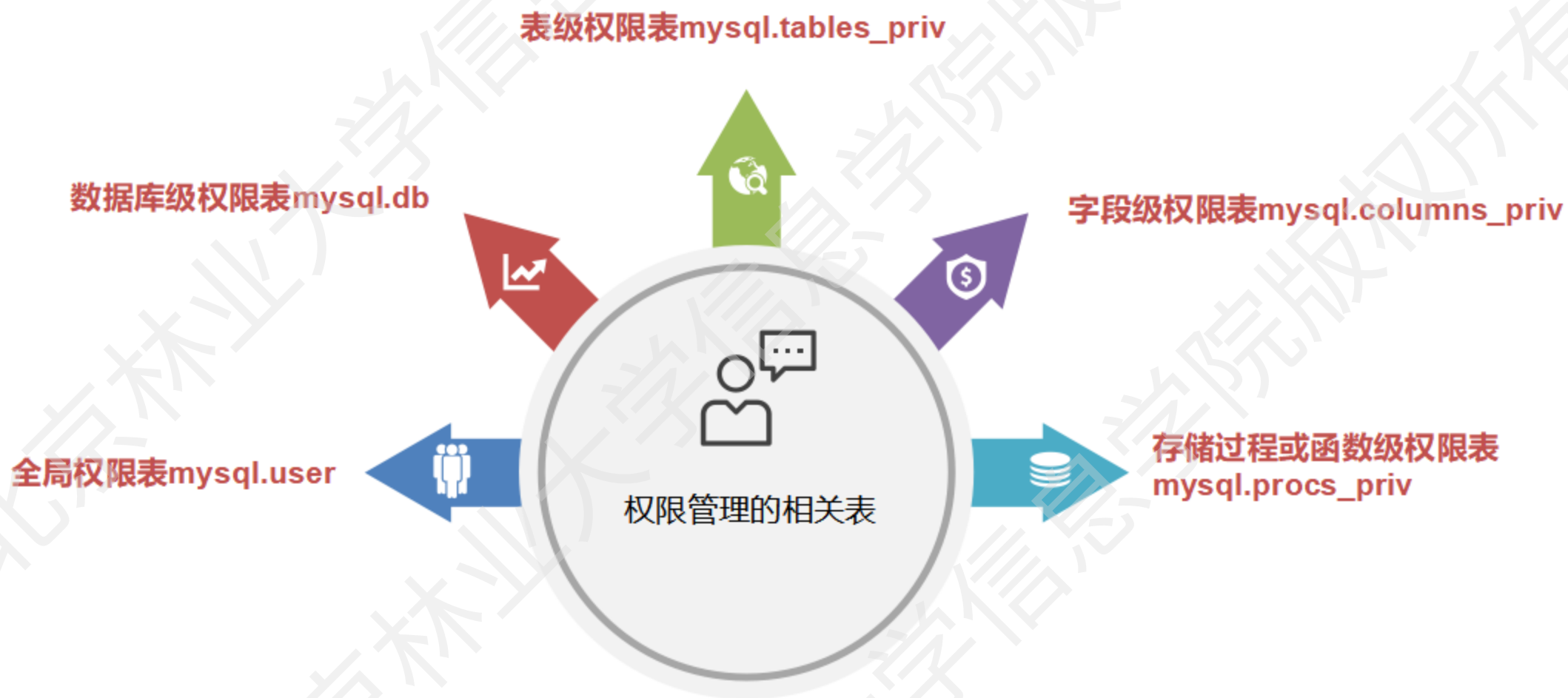
登录验证

权限检查

- 用户通过登录验证后，MySQL将对用户提交的每项数据库操作进行权限检查，判断用户是否具有足够的权限执行相应操作。



权限管理的相关表



全局权限表mysql.user:

用户身份验证相关字段

User (主码)

Authentication_string

Host (主码)

一般权限字段

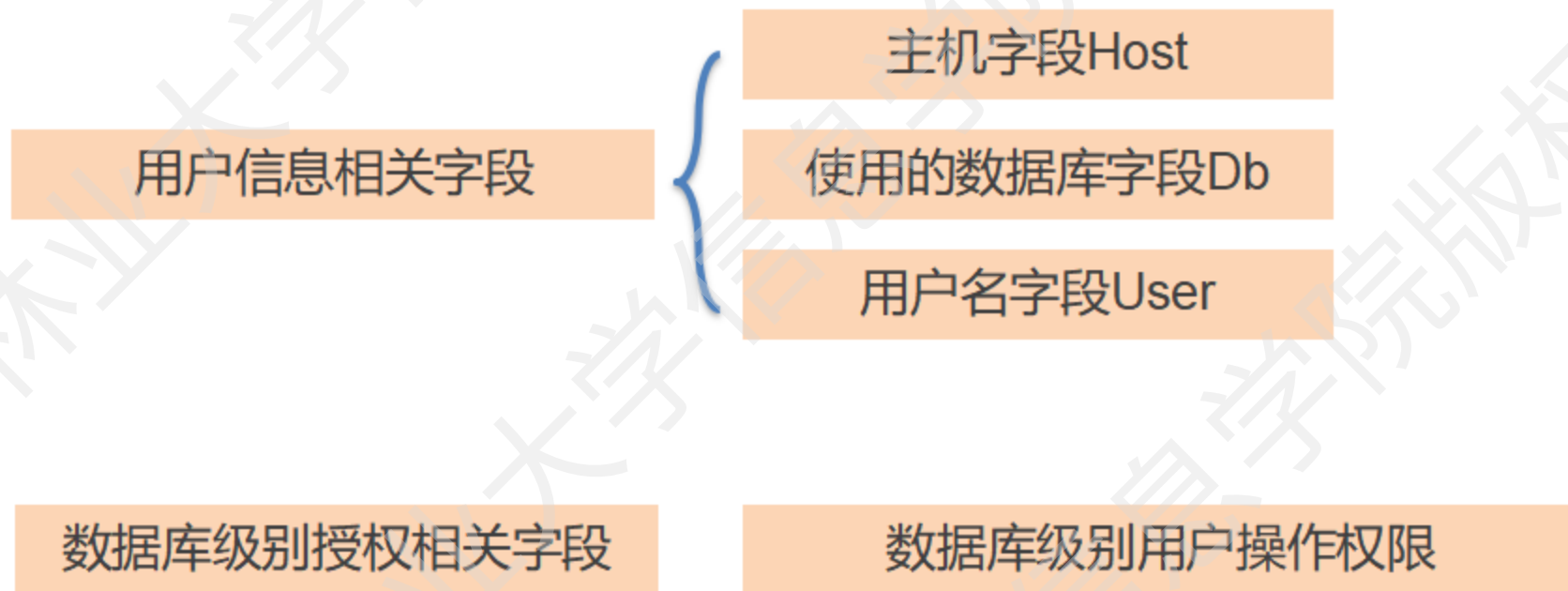
全局权限授予相关字段

管理权限字段

用户安全连接认证配置字段

数据库资源使用约束字段

数据库级权限表mysql.db:



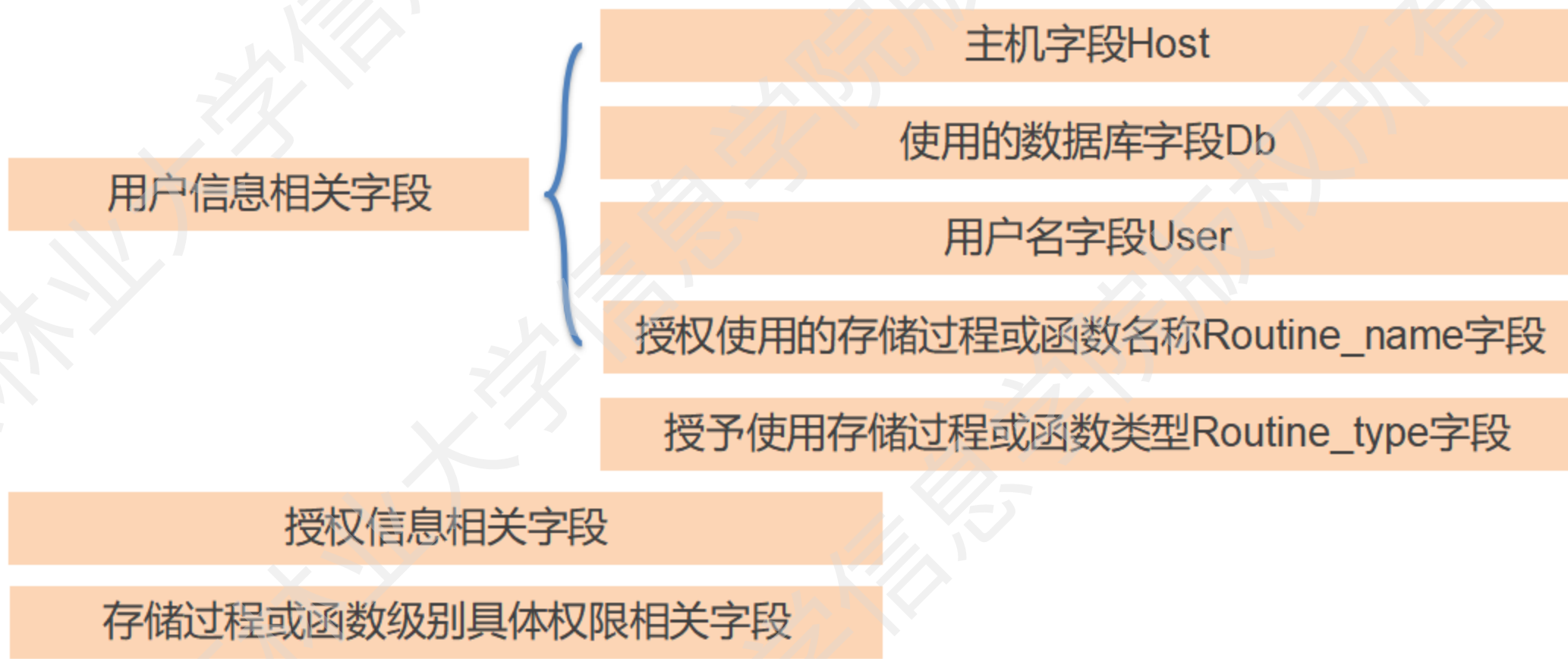
表级权限表mysql.tables_priv:



字段级权限表mysql.columns_priv:



存储过程或函数级权限表mysql.procs_priv:



01

OPTION

数据库安全性定义

Security

02

OPTION

MySQL权限系统

MySQL Privilege

03

OPTION

MySQL用户管理

MySQL User Admin

04

OPTION

MySQL权限管理

MySQL Privilege Admin

05

OPTION

MySQL角色管理

MySQL Role Admin





添加用户

1. 使用CREATE USER语句创建普通用户



```
CREATE USER [IF NOT EXISTS] '用户名'[@'主机地址或标识']  
[IDENTIFIED [WITH AUTH_PLUGIN] BY '用户口令' | RANDOM PASSWORD]  
[WITH resource_option [resource_option] ...]  
[password_option];
```

- 使用CREATE USER语句可一次性创建多个用户，不同用户的配置信息使用逗号分隔。
- 创建用户时，可指定用户访问数据库时允许的主机信息，如主机标识或名称、主机地址或特殊符号，' %' 表示任意位置。
- IDENTIFY子句使用WITH AUTH_PLUGIN指定口令加密策略。通过BY关键字指明口令明文或随机口令RANDOM PASSWORD。
- 可选子句[WITH resource_option [resource_option] ...]使用resource_option配置用户对数据库资源使用约束。
- 可选子句[password_option]设定口令策略。
- CREATE USER语句还提供了其他参数，如用户锁、用户连接安全策略等信息

1. 使用CREATE USER语句创建普通用户

例子：创建一个只允许在MySQL所在服务器上登录账户为student，密码为student123，其他配置信息保持默认。



```
CREATE USER IF NOT EXISTS 'student'@'localhost'  
IDENTIFIED BY 'student123';
```

例子：创建两个用户，其中teacher1用户允许在任何主机访问服务器，其密码为teacher123，teacher2用户只允许在192.168.1.23地址的机器上访问服务器，其密码为随机密码。



```
CREATE USER 'teacher1'@'%' IDENTIFIED BY 'teacher123',  
'teacher2'@'192.168.1.23' IDENTIFIED BY RANDOM PASSWORD;
```

例子：创建一个允许在任何主机访问数据库的用户teacher5，密码为空，用户teacher5每小时最多允许查询为60次，每小时最多允许更新100次。



```
CREATE USER 'teacher5'  
WITH MAX_QUERIES_PER_HOUR 60  
MAX_UPDATES_PER_HOUR 100;
```

2. 使用系统表创建普通用户

使用CREATE USER语句将在系统表mysql.user中添加用户信息，因此，如果拥有mysql数据库的INSERT权限，也可直接向mysql.user表中添加记录，达到与使用CREATE USER语句同样的目的。

例子：使用系统表创建用户teacher6，该用户允许在服务器本地登录，该用户密码为t6123，访问时不适用安全协议SSL。

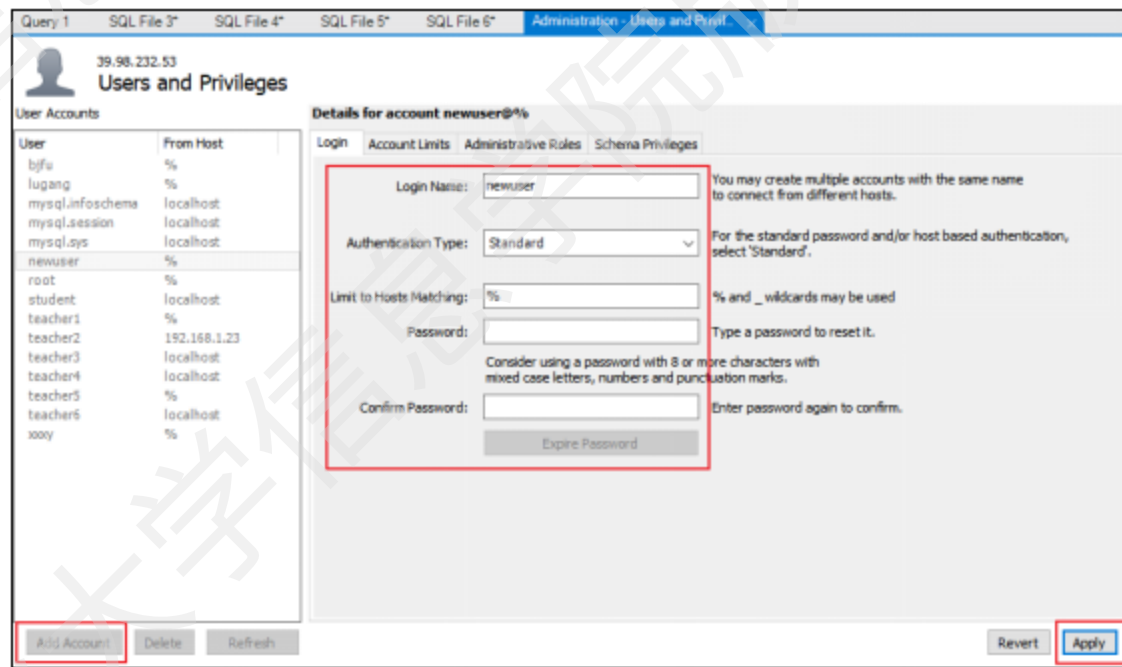
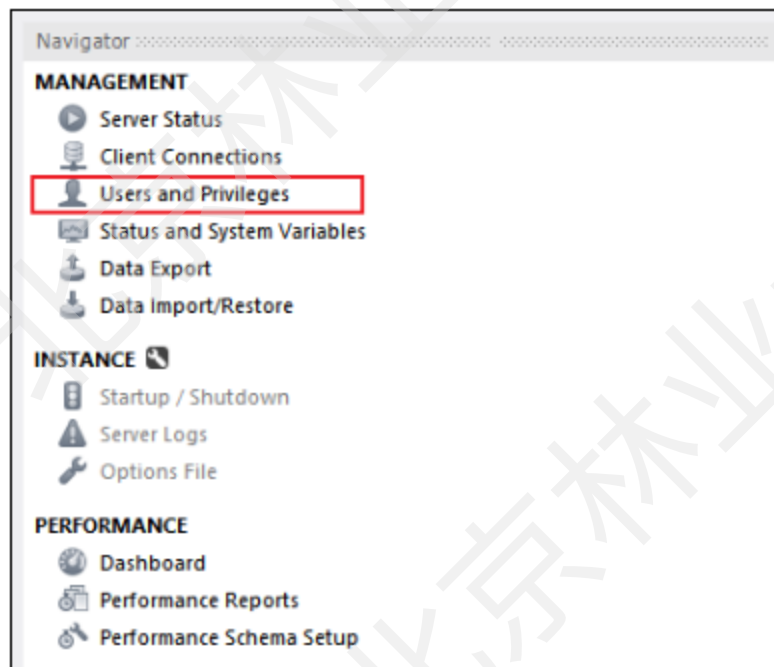
```
INSERT INTO mysql.user (host user, authentication_string, ssl_type, ssl_cipher, x509_issuer, x509_subject)
VALUES('localhost', 'teacher6', sha('t6123'), '', '', '');
```

在实际开发过程中，建议采用更为安全的CREATE USER语句创建用户，不建议直接使用INSERT语句向mysql.user表插入数据实现创建用户。

3. 使用MySQL Workbench创建普通用户

可在Navigator窗格的Administration选项卡下，单击Users and Privileges选项，打开用户管理界面

单击Add Account按钮解锁创建新用户的文本输入框，依次在输入用户名，访问服务器的主机信息、访问口令以及访问口令确认信息



查看用户

1. 使用系统表查看用户

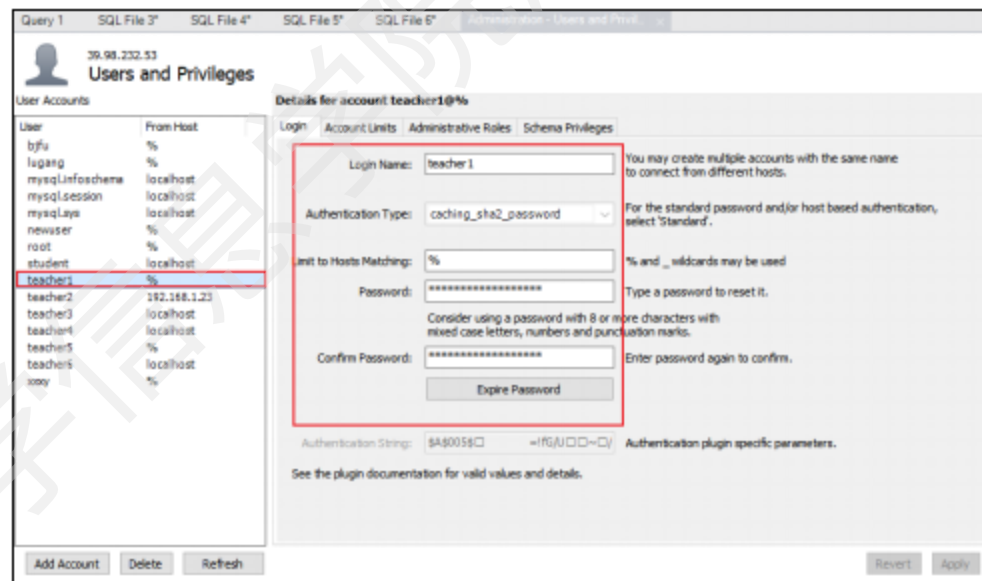
- 查询系统表mysql.user，可以列出系统用户信息和全局权限信息。

例子：查看teacher1的用户名、主机信息以及每小时最大查询执行次数。

SELECT User,Host,max_questions
FROM mysql.user
WHERE User = 'teacher1';

2. 使用MySQL Workbench查看用户

在Navigator窗格的Administration选项卡下，单击Users and Privileges选项，打开用户管理界面



重命名用户账号

1. 使用RENAME USER语句重命名用户账号



RENAME USER '原用户信息' TO '新用户信息'['原用户信息' TO '新用户信息']...

- 可以使用RENAME USER语句一次性为多个已有用户进行重命名，不同用户使用逗号分隔。
- 使用RENAME USER语句实际上是对mysql.user表操作，因此，需要具有mysql数据库的UPDATE权限或服务器级别的CREATE USER权限。
- 使用'用户名'@'主机信息'的形式的用户信息重命名用户，该方式不仅可以重命名用户名称，还可以修改用户允许访问服务器的主机信息。
- 当重命名的用户为定义视图、存储过程时指定的DEFINER属性值，MySQL会阻止用户重命名。

例子：将已有用户teacher1重命名为teacher10，将主机信息从%修改为localhost。



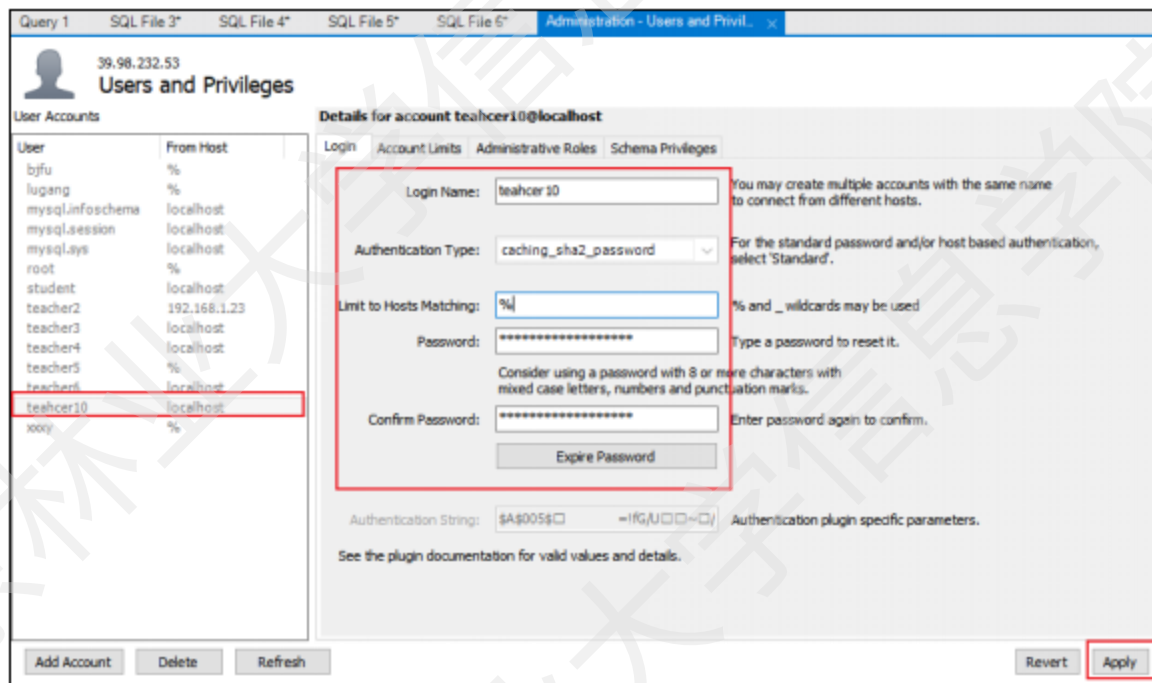
```
RENAME USER 'teacher1'@'%' to 'teahcer10'@'localhost';
```

重命名用户账号

2. 使用MySQL Workbench重命名用户账号

在Navigator窗格的Administration选项卡下，单击Users and Privileges选项

在Login选项卡中输入重命名用户账号信息，修改完成后，单击Apply按钮提交修改请求



修改用户口令

1. 使用mysqladmin命令修改用户口令



```
mysqladmin -u 用户名 p password
```

- 输入上述命令后，命令行提示首先输入原密码。原密码正确后，提示输入新密码和确认新密码。
- mysqladmin命令位于MySQL服务器安装路径的bin文件夹下，如果在任意文件夹下执行该命令，需将mysqladmin所在bin目录放在环境变量Path下。

2. 使用SET PASSWORD语句修改用户口令



```
SET PASSWORD [FOR '用户名'@'主机信息'] = '新密码';
```

例子：将主机信息为localhost、用户名为student的用户口令修改为student123。



```
SET PASSWORD FOR 'student'@'localhost'='student123';
```

修改用户口令

4. 使用ALTER USER语句修改用户口令



```
ALTER USER '用户名'@'主机信息' IDENTIFIED BY '新密码';
```

例子：将主机信息为localhost、用户名为student的用户口令修改为student123。



```
ALTER USER 'student'@'localhost' IDENTIFIED BY 'student123';
```

4. 使用系统表修改用户口令

例子：将主机信息为localhost、用户名为student的用户口令修改为student123。



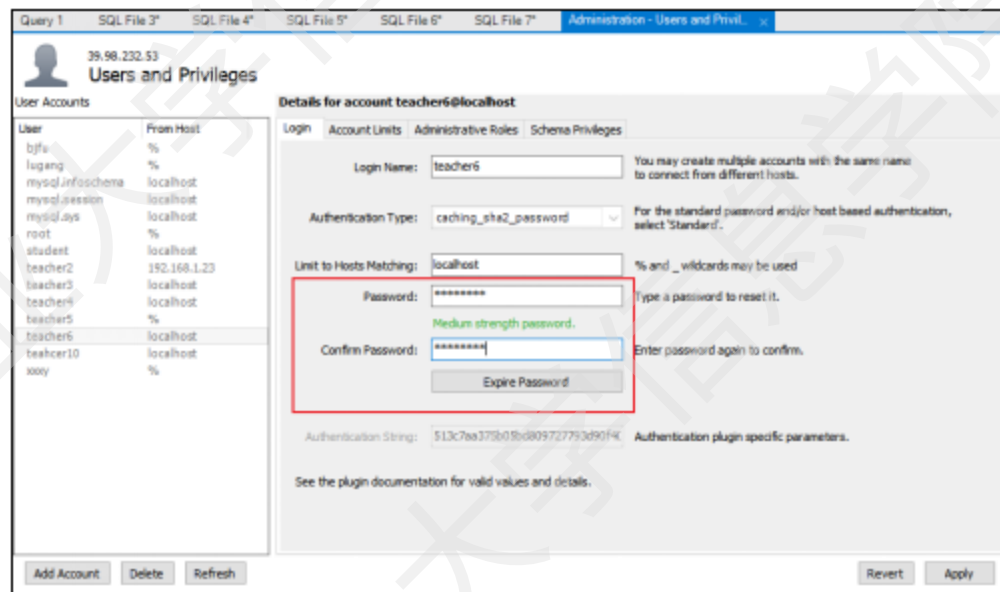
```
UPDATE mysql.user  
SET authentication_string=sha('student123')  
WHERE User = 'student' and Host = 'localhost';
```

修改用户口令

5. 使用MySQL Workbench修改用户口令

在Navigator窗格的Administration选项卡下，单击Users and Privileges选项，打开用户管理界面

选择需要修改的用户名称，在右侧先后在Password和Confirm Password文本框内输入新密码和确认新密码，单击Apply按钮提交修改申请



删除用户

1. 使用DROP USER语句删除用户



DROP USER '用户名'@'主机信息'[, '用户名'@'主机信息']...

例子：删除主机信息为localhost用户名为student的用户。



DROP USER 'student'@'localhost';

2. 使用系统表删除用户

例子：删除主机信息为localhost、用户名为techer4的用户。



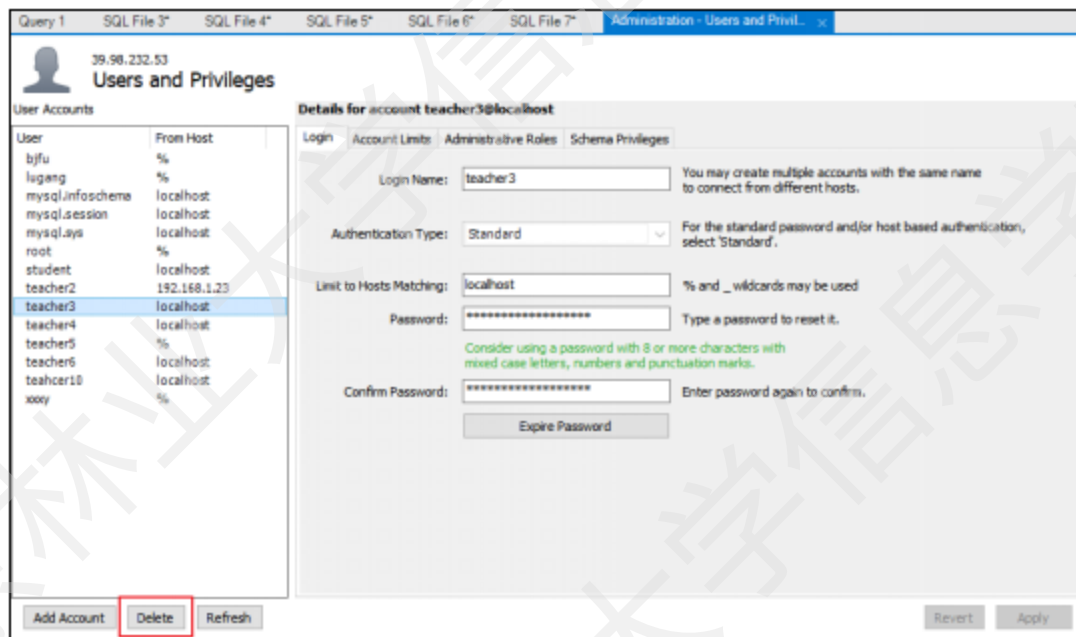
DELELE FROM mysql.user
WHERE User = 'student' and Host = 'localhost';

删除用户

3. 使用MySQL Workbench删除用户

在Navigator窗格的Administration选项卡下，单击Users and Privileges选项

用户列表中，选择需要删除的用户名称，单击Delete按钮删除用户



01

OPTION

数据库安全性定义

Security

02

OPTION

MySQL权限系统

MySQL Privilege

03

OPTION

MySQL用户管理

MySQL User Admin

04

OPTION

MySQL权限管理

MySQL Privilege Admin

05

OPTION

MySQL角色管理

MySQL Role Admin





权限授予

1. 使用GRANT语句授予权限



GRANT 权限名称[(字段列表)][,权限名称[(字段列表)]]...
ON 授权层次及对象
TO '用户名'@'主机信息'[, '用户名'@'主机信息']...
[WITH GRANT OPTION];

- 可以一次性将多个权限赋予用户，不同权限名称使用逗号分隔。
- ON子句用于指明授权级别及对象，常见形式包括：
 - *.*为服务器级别权限（全局权限）修改mysql.user表中记录
 - db_name.*为数据库级别权限，修改mysql.db表中记录
 - db_name.table_name为表或列级别权限，授予表级别权限将修改mysql.tables_priv表中记录，授予列级别权限将修改mysql.columns_priv表中记录
 - db_name.routine_name为存储过程级别权限，修改mysql.routines_priv表中记录
- TO子句用于指明授予的用户，可以使用TO子句将权限授予多个用户
- (6) 使用GRANT语句需要具有GRANT OPTION权限且具有授权权限的操作权限。

权限授予

1. 使用GRANT语句授予权限

例子：为teacher10用户赋予数据库服务器的所有使用权限（ALL），并允许权限由teacher10授予其他用户。



```
GRANT ALL  
ON *.* TO 'teacher10'@'localhost'  
WITH GRANT OPTION;
```

例子：为teacher6用户赋予数据库服务器级别的查找、插入和更新数据权限（SELECT、INSERT、UPDATE），并且不允许二次授权。



```
GRANT SELECT, INSERT, UPDATE  
ON *.* TO 'teacher6'@'localhost';
```

权限授予

1. 使用GRANT语句授予权限

例子：为teacher4用户赋予teaching数据库上对象的查找、创建数据表和插入数据权限（SELECT、CREATE、INSERT），并不允许权限由teacher4授予其他用户。



```
GRANT SELECT,CREATE, INSERT  
ON teaching.* TO 'teacher4'@'localhost';
```

例子：为teacher3用户赋予teaching数据库上教师表t的查找、插入、更新和删除数据权限（SELECT、INSERT、UPDATE、DELETE），并不允许权限由teacher3授予其他用户。



```
GRANT SELECT, INSERT, UPDATE, DELETE  
ON teaching.t TO 'teacher3'@'localhost';
```

权限授予

1. 使用GRANT语句授予权限

例子：为teacher2用户赋予teaching数据库中教师表t上tno字段和tn字段的查找数据权限（SELECT），并不允许权限由teacher2授予其他用户。



```
GRANT SELECT(tno, tn)  
ON teaching.t TO 'teacher2'@'192.168.1.23';
```

使用GRANT语句的其他注意事项：

- MySQL 8不允许为不存在用户授权，所以不能使用GRANT语句达到授权同时创建用户的目的，必须先创建用户，然后才能授权。
- 对于字段级别权限，由于只能对字段进行查询、插入和更新操作，所以字段级别权限只支持SELECT、INSERT和UPDATE权限。
- 使用GRANT语句授予不同级别的权限，将在相应的权限表格中，创建或修改相应记录。

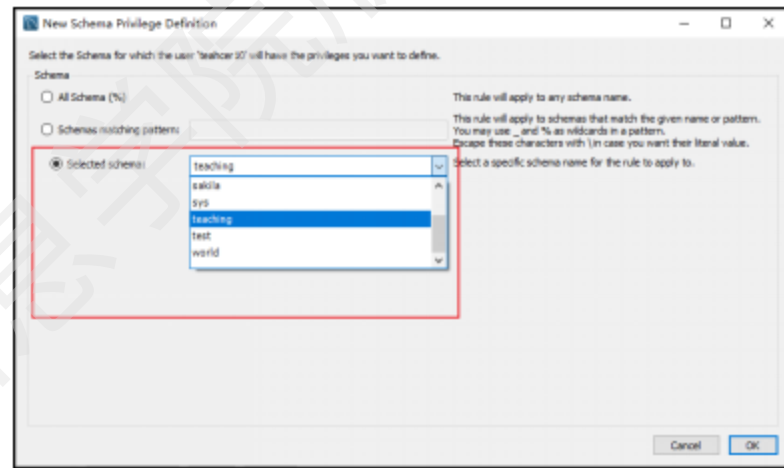
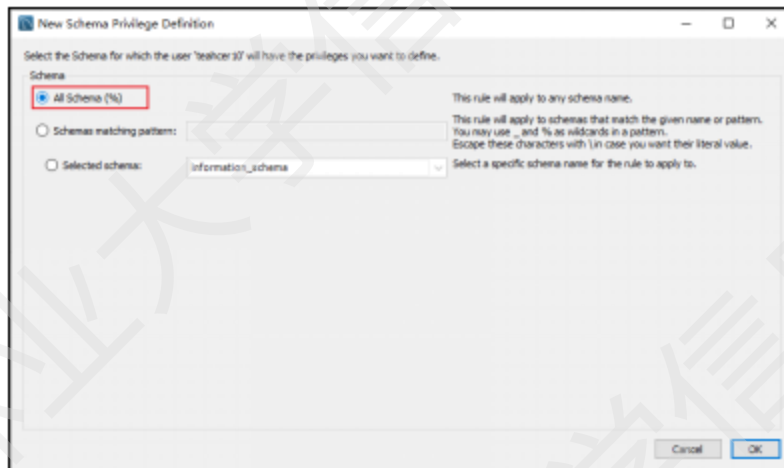
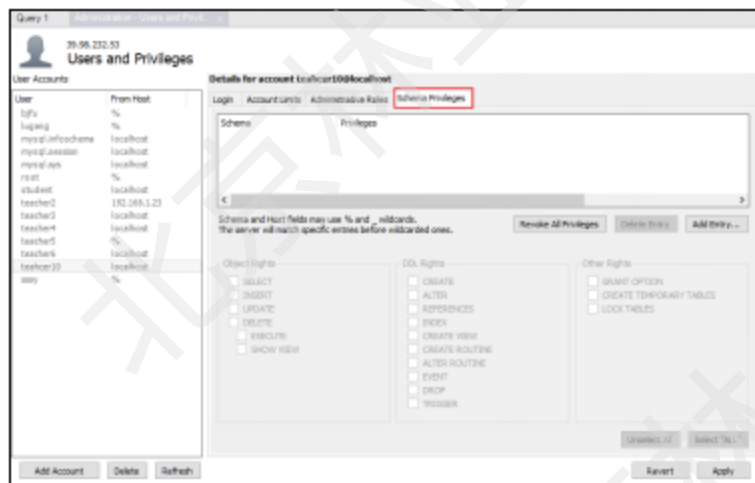
权限授予

2. 使用MySQL Workbench授予权限

在Navigator窗格的Administration选项卡下，单击Users and Privileges选项，打开用户管理界面

在User Accounts窗格中，选择需要授权的用户。在右侧窗格中，选择Schema Privileges选项卡进入授权界面

单击Add Entry按钮，设置授权级别，如图8-11所示。选择ALL Schema选项，表示授予服务器级别权限



权限查看

1. 使用SHOW GRANTS语句查看权限授予情况

角色

权限1

权限2

权限3

在Navigator窗格的Administration选项卡下，单击Users and Privileges选项，打开用户管理界面

权限查看

1. 使用SHOW GRANTS语句查看权限授予情况



SHOW GRANTS FOR '用户名'@'主机信息';

例子：查看localhost主机上student用户的权限授予情况。

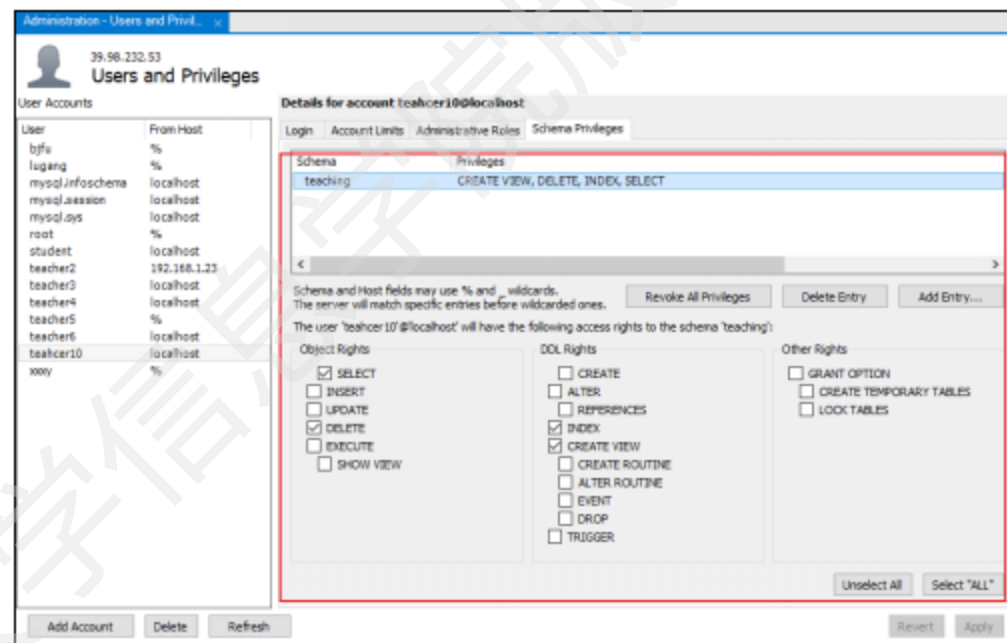


SHOW GRANTS FOR 'student'@'localhost';
SHOW GRANTS FOR CURRENT_USER;

2. 使用MySQL Workbench查看权限授予情况

在Navigator窗格的Administration选项卡下，单击Users and Privileges选项，打开用户管理界面

在User Accounts窗格中，选择需要查看授权的用户。



权限回收

1. 使用REVOKE语句回收权限



REVOKE 权限名称[(字段列表)][,权限名称[(字段列表)]]...
ON 回收权限的层次及对象
FROM '用户名'@'主机信息'[, '用户名'@'主机信息']...;

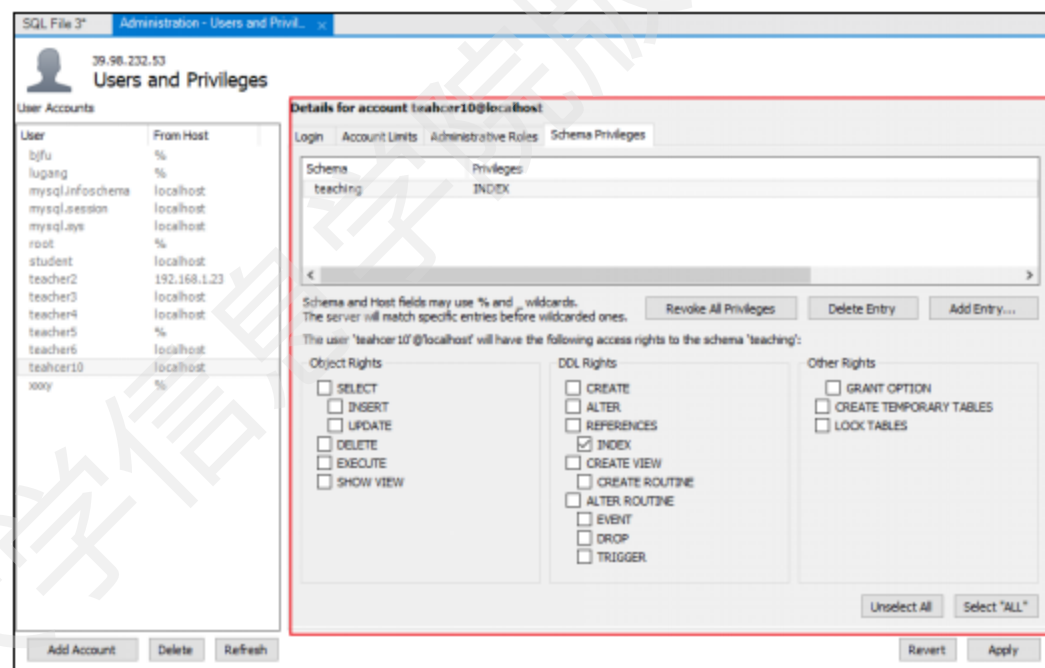
例子：回收localhost主机上teacher10用户对数据库中对象的DELETE权限和SELECT权限。



REVOKE SELECT, DELETE
ON teaching.*
FROM 'teacher10'@'localhost';

2. 使用MySQL Workbench回收权限

在Navigator窗格的Administration选项卡下，单击Users and Privileges选项，在User Accounts窗格中，选择需要回收权限的用户



权限转移

1. 使用REVOKE语句回收权限



使用GRANT语句中WITH GRANT OPTION参数表明允许权限转移。

例子：为localhost上teacher3用户授予teaching.t上查找SELECT和UPDATE权限，并允许teacher3用户将权限上述权限转移给其他用户。



```
GRANT SELECT, UPDATE  
ON teaching.t  
TO 'teacher3'@'localhost'  
WITH GRANT OPTION;
```

01

OPTION

数据库安全性定义

Security

02

OPTION

MySQL权限系统

MySQL Privilege

03

OPTION

MySQL用户管理

MySQL User Admin

04

OPTION

MySQL权限管理

MySQL Privilege Admin

05

OPTION

MySQL角色管理

MySQL Role Admin



角色与用户的关系

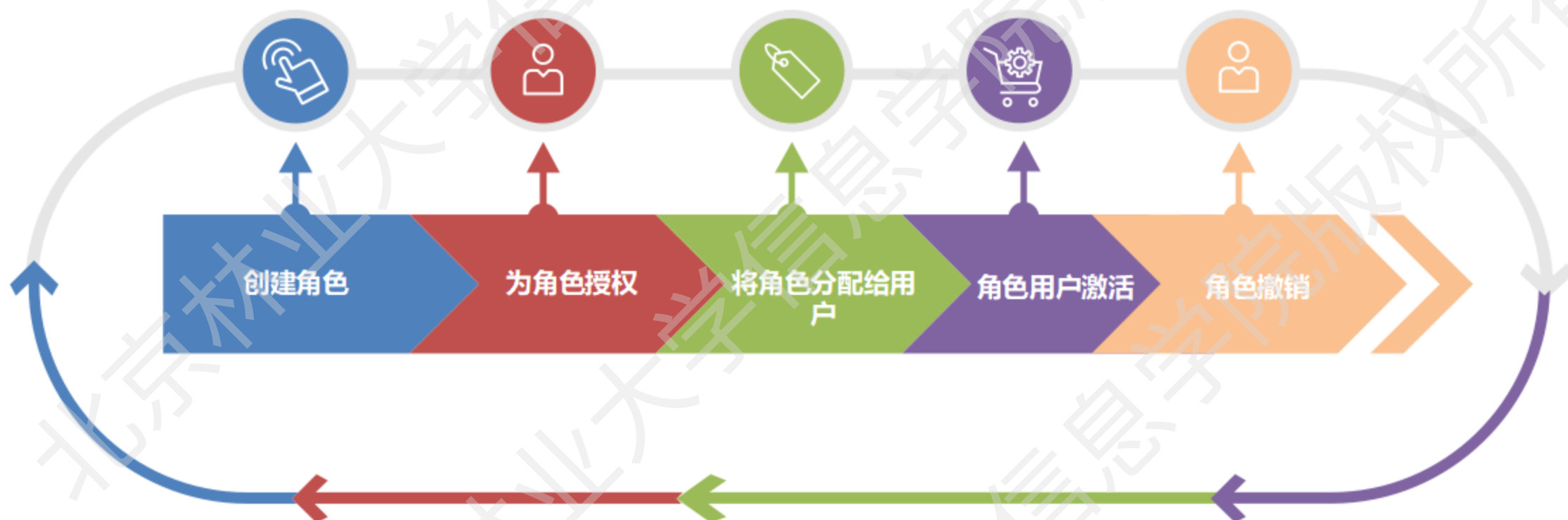
角色 (Role) 是对权限集中管理的一种机制，通常根据特定需要，将一系列权限集中在一起构成角色。



使用角色可以更加方便和自然的为用户授予权限。

- ✓ 从MySQL 8开始，允许使用角色授权。
- ✓ 一个用户可以分配多个角色，也允许一个角色分配给多个用户。

角色生命周期



角色创建

使用CREATE ROLE语句创建角色



```
CREATE ROLE '角色名称'@'主机信息'[, '角色名称'@'主机信息']...
```

例子：创建可在任意主机上使用的教师角色teacher和管理员角色administrator。



```
CREATE ROLE 'teacher', 'administrator';
```

例子：创建可在本地主机上使用的开发者角色developer。



```
CREATE ROLE 'developer'@'localhost';
```

角色授权

使用GRANT语句将角色包含的权限赋予角色。

例子：为管理员角色administrator授予服务器级别全局权限。



```
GRANT ALL PRIVILEGE ON *.* TO administrator;
```

例子：为教师角色teacher授予teaching.sc表级别的查找SELECT、插入数据INSERT、更新数据UPDATE和删除数据DELETE权限。



```
GRANT SELECT, INSERT, UPDATE, DELETE  
ON teaching.sc  
TO 'teacher';
```

角色激活

1. 为用户分配角色

例子：为用户teacher2分配teacher角色。



```
GRANT 'teacher' TO 'teacher2';
```

2. 角色激活

例子：使用户teacher2上的teacher角色生效。



```
SET DEFAULT ROLE 'teacher' TO 'teacher2';
```

例子：使用户teacher3上的所有角色生效。



```
SET DEFAULT ROLE ALL TO 'teacher3';
```

MySQL角色查看

使用SELECT语句查询CURRENT_ROLE函数可获得当前用户的生效角色

例子：查询当前用户生效的角色。



```
SELECT CURRENT_ROLE();
```

MySQL角色撤销

使用REVOKE语句可以回收已经分配给各用户的角色，回收后用户不再具有角色拥有的权限。

例子：回收用户teacher2的角色teacher。



```
REVOKE 'teacher2' FROM 'teacher';
```

例子：删除角色teacher。



```
DROP ROLE 'teacher';
```



人邮教育

www.ryjiaoyu.com

更多样书申请和资源下载需求，请登录人邮教育社区
(www.ryjiaoyu.com)

海量图书方便查询

囊括各大品类，您想要的应有尽有

免费申请样书

教师免费申请样书，
我们将安排快递迅速送达

下载配套资源

教学视频、PPT课件、教学案例、
习题答案、模拟试卷等丰富资源
免费下载



优惠购书

教师可以申请最低折扣
学生直接优惠购买图书

成为作者

欢迎写文章 / 投稿，我们强大的编辑团队将为您提供专业和高效的编辑出版服务